

로그인 성공/실패 테스트 결과

AI 역량테스트 플랫폼 · 증적관리 02_로그인

실행일: 2026-08-06 실행 명령: node --test (backend/test/api.test.mjs) 결과: 28/28 PASS

1. 자동화 테스트 기반 검증 결과

No	시나리오	요청 조건	기대 결과	실제 결과	판정
1	정상 계정 로그인 성공	email:admin@aivle.com password:123, role:ADMIN	200 OK, 사용자 role 포함 응답	200 OK (role: ADMIN)	PASS
2	승인 대기 계정 로그인 차단	승인 전 신규 관리자 계정으로 로그인	403 Forbidden	403 Forbidden	PASS
3	관리자 승인 후 로그인 성공	동일 계정, ADMIN 승인 처리 후 재로그인	200 OK, 인증 토큰 발급	200 OK (token 발급)	PASS
4	인증 토큰 없이 보호 API 접근 차단	Authorization 헤더 없이 /api/admin/users 요청	401 Unauthorized	401 Unauthorized	PASS
5	이메일 인증 코드 5회 오류 후 잠금	잘못된 인증코드 5회 연속 입력	5회 모두 401, 6회차 429	401 x5, 429	PASS

※ 위 5건은 backend/test/api.test.mjs의 실제 테스트 실행(node --test)에서 발췌한 결과이다.

2. 코드 기준 확인 — 잘못된 비밀번호 로그인 실패 처리

잘못된 비밀번호로 로그인 시 401과 함께 표준 오류 메시지를 반환하고, 동일 IP·이메일 조합으로 5회 연속 실패 시 15분간 로그인을 잠그는 로직이 구현되어 있다. 다만 현재 자동화 테스트 스위트(api.test.mjs)에는 '잘못된 비밀번호' 단일 케이스에 대한 전용 테스트가 없어, 아래는 코드 검토로 확인한 결과이다.

```
// backend/src/app.mjs (로그인 라우트)
const lock = loginFailures.get(key);
if (lock?.blockedUntil && lock.blockedUntil > Date.now())
  return response.status(429).json({ message: "로그인 시도가 너무 많습니다. 잠시 후 다시 시도해주세요." });
```

```
if (!roleMatches || ... || !(await verifyPassword(password ?? "", user.passwordHash))) {  
  if (user && user.approvalStatus !== "APPROVED") return response.status(403).json(...);  
  const failures = (loginFailures.get(key)?.failures ?? 0) + 1;  
  loginFailures.set(key, { failures, blockedUntil: failures >= 5 ? Date.now() + 15*60*1000 : 0 });  
  return response.status(401).json({ message: "이메일, 비밀번호 또는 권한을 확인해주세요." });  
}
```

3. 종합 결과

- 자동화 테스트로 검증된 5개 시나리오 모두 PASS
- 로그인 실패 제한(brute-force 방지) 정책은 코드상 구현이 확인되나 전용 자동화 테스트 부재 — 추가 권고
- 권고: '잘못된 비밀번호 → 401', '5회 실패 → 429 잠금' 시나리오에 대한 단위 테스트를 api.test.mjs에 추가할 것